1. Roles and access control

Every account has one role. The role is stored with the account and read at sign-in.

Role	Who	How the account is created
CUSTOMER	Store customers	Self sign-up on the Sign In page, or the sample data
ADMIN	Store administrators	Sample data only (user `admin`). There is no screen to create an administrator.

1.1 Access matrix

Page / function	Anonymous	CUSTOMER	ADMIN
Home, category, product, item, search	Yes	Yes	Yes
Sign In, create account	Yes	Yes	Yes
My Account (`account.screen`)	Sign In page shown	Yes	Yes
Catalog Administration (`populate_admin.screen`)	Sign In page shown	Access Denied	Yes
First load of sample data (empty database)	Yes	Yes	Yes
Forced reload of sample data	Access Denied	Access Denied	Yes

Java™ Pet Store Lite

Administrator Guide

Document	PSL-AG-01
Version	1.3.2-lite-1
Audience	Store administrators (role ADMIN)
Related	PSL-UG-01 User Guide, PSL-RB-01 Operations Runbook

Protected pages are listed in `WEB-INF/signon-config.xml`. A page with an `auth-constraint` is open only to the roles listed; a page without one is open to any signed-in user. When an anonymous user opens a protected page, the Sign In page is shown and, after a successful sign-in, the user is sent back to the page first asked for.

When signed in as ADMIN the banner shows an extra **Admin** link.

1.2 Sample accounts

User name	Role	Password
j2ee	CUSTOMER	j2ee
shopper	CUSTOMER	j2ee
admin	ADMIN	admin

> Change these passwords before the store is used outside a test environment. Passwords are stored as entered in table SIGNON.

2. Sign-on rules

#	Rule
R1	A sign-in succeeds when the user exists, is not locked and the password matches exactly.
R2	Each failed sign-in adds 1 to the account's failed attempts. A successful sign-in sets it back to 0.
R3	The 3rd failure in a row locks the account (LOCKED = Y) and records the time of the lock.
R4	A locked account cannot sign in, even with the right password. The attempt is recorded as SIGNON_LOCKED and the failed count does not change.
R5	Batch job PSL_ACCT_UNLOCK runs every 15 minutes and unlocks accounts locked more than 30 minutes ago. It sets failed attempts to 0 and records ACCOUNT_UNLOCKED.
R6	A sign-in with an unknown user name is recorded as SIGNON_FAIL against the name typed.
R7	Every sign-in, failure, lock, sign-out and new account is written to SIGNON_AUDIT with the time and the client address.
R8	Sessions time out after 15 minutes without activity.

2.1 Unlock an account at once

There is no unlock screen. To unlock before the batch job runs, ask operations to run PSL_ACCT_UNLOCK on demand (it only unlocks locks older than 30 minutes) or to run this SQL as the store schema owner:

```
UPDATE signon SET locked = 'N', failed_attempts = 0, locked_ts = NULL WHERE username
= '<user>';
INSERT INTO signon_audit (username, event_type, event_ts, remote_addr)
  VALUES ('<user>', 'ACCOUNT_UNLOCKED', CURRENT_TIMESTAMP, 'admin');
```

3. Catalog administration

The catalog and the sample accounts come from two files in the web application:

File	Content
`populate/Populate-UTF8.xml`	Users (id, password, role) and the catalog: 5 categories, 16 products, 28 items
`populate/PopulateSQL.xml`	Create, insert, check and drop statements per table, for `derby` and `oracle`

3.1 First load

When a user clicks *enter the store*, the store calls `Populate?forcefully=false`. If the catalog and SIGNON tables already hold data nothing happens. Otherwise every table is dropped, created and loaded. No sign-in is needed for the first load.

3.2 Reload the sample data

1. Sign in as an ADMIN user.
2. Click **Admin** in the banner. The page *Catalog Administration* opens.
3. Click **Reload Sample Data**.
4. The store drops and recreates CATEGORY, CATEGORY_DETAILS, PRODUCT, PRODUCT_DETAILS, ITEM, ITEM_DETAILS, SIGNON and SIGNON_AUDIT, loads the file, ends your session and shows the home page.

> A reload deletes every account created in the store and all sign-in history. Take a backup first (job PSL_DB_BACKUP).

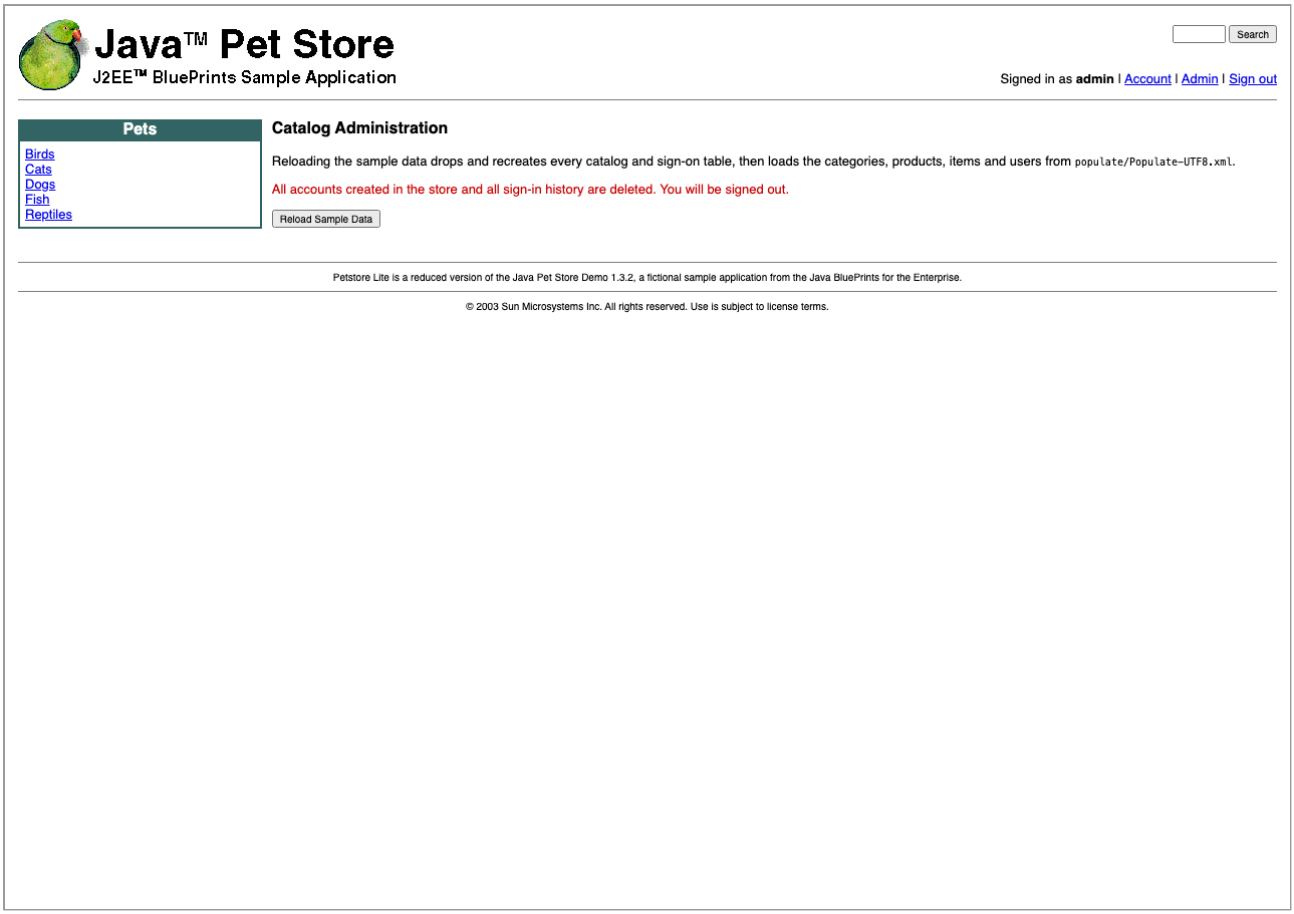


Figure 1. Catalog Administration (ADMIN only)

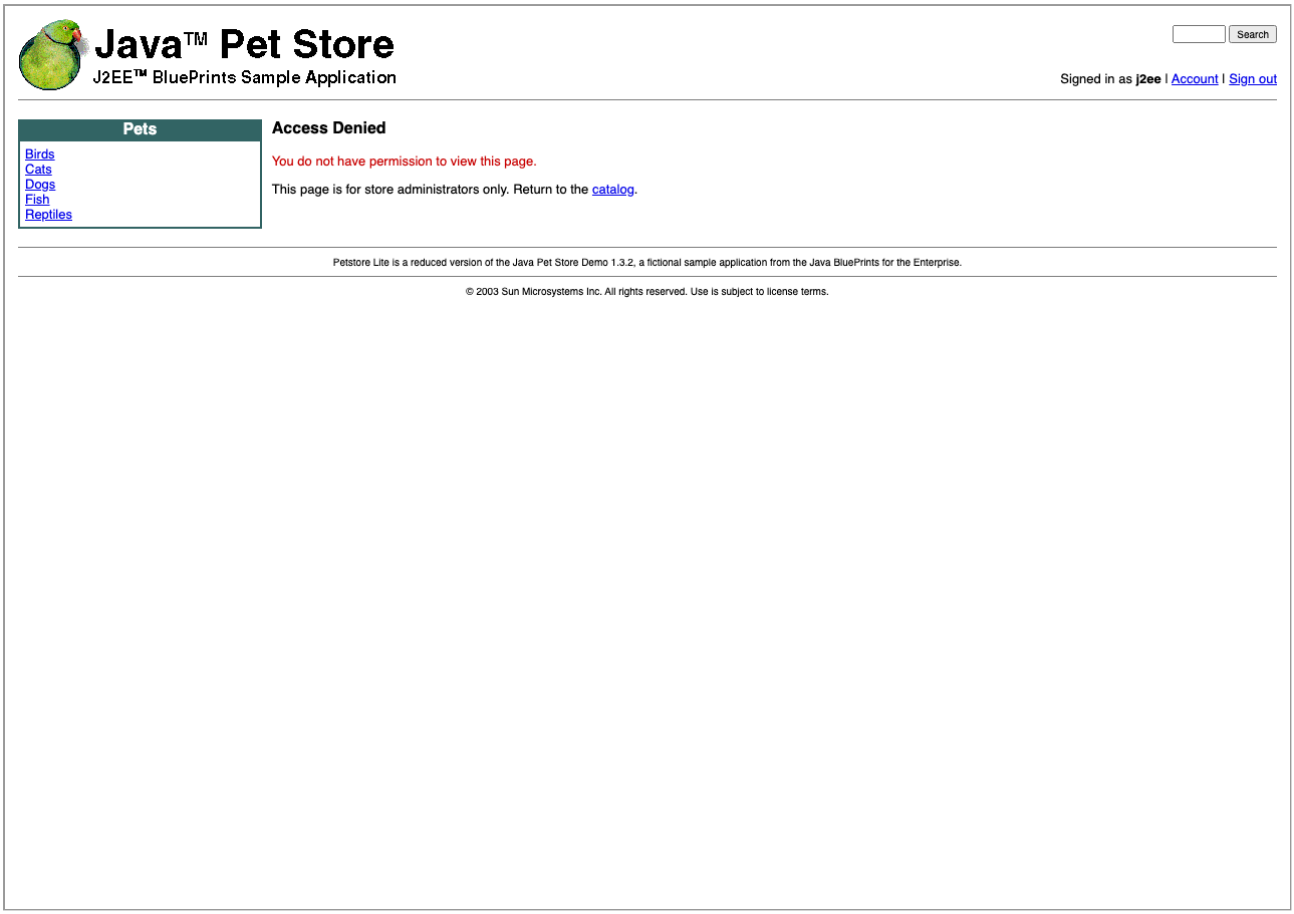


Figure 2. Access Denied shown to a CUSTOMER

3.3 Catalog data rules

#	Rule
C1	Every category has at least one product.
C2	Every product has at least one item.
C3	An item's list price is never below its unit cost (database check constraint).
C4	Every item has an en_US description.

Job PSL_CATALOG_CHECK checks C1 to C4 every morning at 06:00 and alerts the catalog team when one fails.

4. Configuration

Setting	Where	Value
Data source	`META-INF/context.xml`, JNDI `jdbc/CatalogDB`	Derby, `/var/petstore/db/PetStoreDB`, user estoreuser
Database dialect for SQL	`web.xml` env-entry `param/CatalogDAODatabase` and PopulateServlet `Database`	derby (or oracle)
Catalog SQL	`CatalogDAOSQL.xml`	GET_CATEGORY, GET_CATEGORIES, GET_PRODUCT, GET_PRODUCTS, GET_ITEM, GET_ITEMS, SEARCH_ITEMS
Protected pages	`WEB-INF/signon-config.xml`	account.screen, signon_welcome.screen, populate_admin.screen (ADMIN)
Screens	`WEB-INF/screendefinitions_en_US.xml`	15 screens on one template
Session timeout	`web.xml`	15 minutes
Batch settings	`conf/petstore.properties`, `conf/env.sh`	See the Operations Runbook